

《信息安全综合实验》实验报告

实验 4：使用 Burp Suite 对 HTTPS 流量进行中间人篡改

姓名：蒋桢言 学号：2313546

1 实验目的及内容

实验目的：

1. 初步了解 Burp Suite 的使用方式。
2. 掌握中间人攻击原理、TLS 保护的通信过程以及对 HTTPS 实现中间人攻击的具体流程。
3. 在实践中加深对于中间人流量劫持和 HTTPS 原理的理解。

实验内容：

1. 利用自己的电脑搭建热点，使用 Burp Suite 对手机（作为被攻击者）访问的任意 HTTPS 网页进行拦截并篡改响应内容，观察攻击效果。
2. 尝试对除浏览器外的任一 APP 的流量进行拦截篡改。如果失败，尝试分析原因；如果成功，简述实验过程。

2 实验环境

准备一台配有无线网卡的电脑，安装 Burp Suite；一部安卓手机作为被攻击设备。

电脑打开移动热点，如图1所示。手机输入密码连接热点，并手动配置代理：主机名填写网关 192.168.137.1，端口选择 8080，如图2所示。连接成功后，电脑上显示连接的设备的信息，如图3所示。



图 1：电脑热点配置



图 2: 手机连接配置

已连接的设备: 1 台(共 8 台)		
设备名称	IP 地址	物理地址(MAC)
vivo-S16-Pro	192.168.137.60	72:6d:dc:47:35:26

图 3: 连接信息

3 实验过程

3.1 Burp Suite 配置

打开 Burp Suite，进入 Proxy settings，Proxy listeners 添加对应网关和端口，如图4所示。

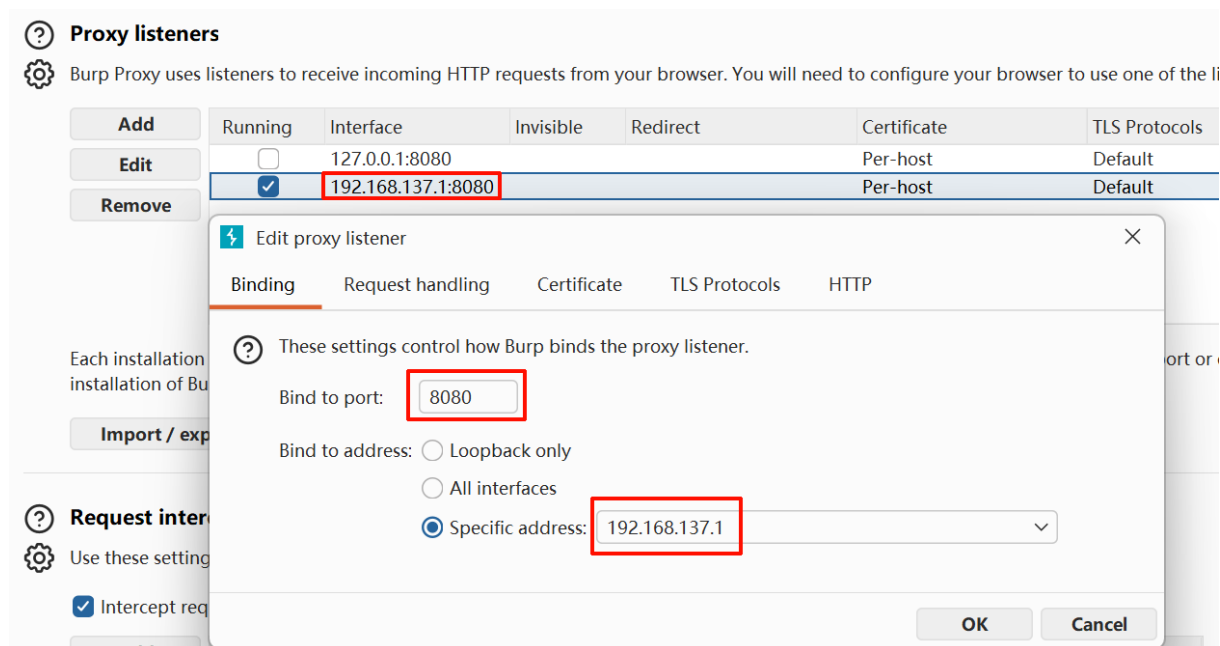


图 4: Proxy listeners 设置

根据一会儿我们想要篡改的网页，在 Request interception rules 添加规则 URL Matches nankai.edu.cn，只要 URL 里包含 nankai.edu.cn，就会命中规则被拦截，如图5所示。

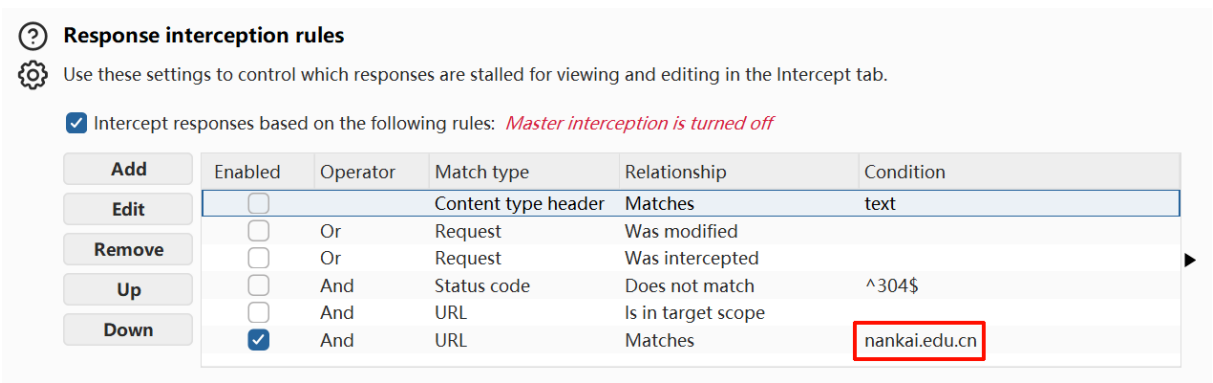


图 5: Request interception rules 设置

3.2 证书安装

现在手机随便访问一个网站（例如百度），发现显示如图6所示。这是由于我在做“中间人代理”，Burp Suite 返回给手机的证书是它自己的证书，而手机不信任 Burp Suite 的证书，所以浏览器认为这个网站的证书是假的，可能有人在窃听（MITM 攻击）。



图 6: 证书链验证失败

手机浏览器访问 http://burp 下载证书（cacert.der）（如图7所示），在设置里安装刚刚下载的 CA 证书，如图8所示。

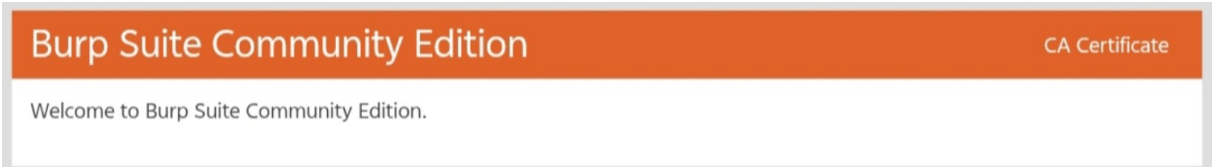


图 7: 下载 Burp 证书

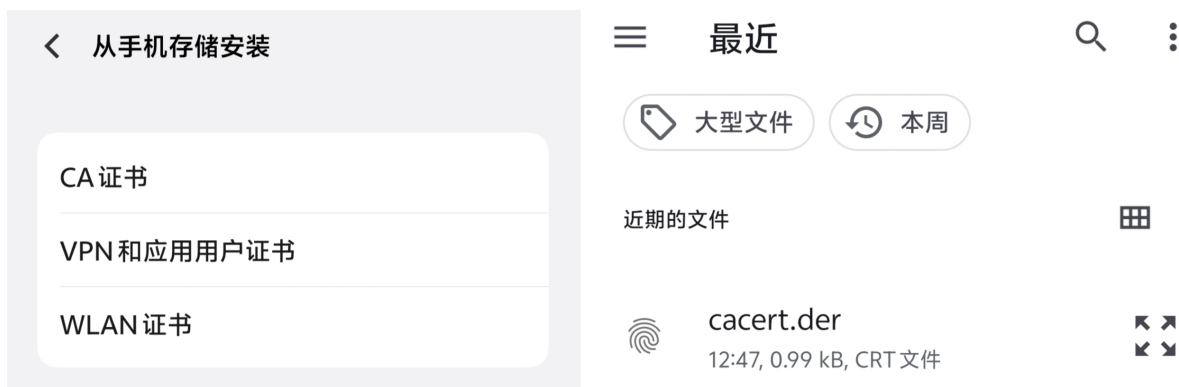


图 8: 安装证书

我们访问南开大学的一个新闻页面（作为等下要篡改的页面）：

`https://news.nankai.edu.cn/mtnk/system/2026/04/18/030071471.shtml`

发现成功显示了结果，没有再提示证书的问题，如图9所示。



图 9: 访问待篡改的页面

3.3 拦截并篡改响应内容

现在打开 Burp Suite 的拦截开关，打开后手机再次访问这个 URL，发现请求已经被拦截了下来，如图10所示。

 Intercept on	 Forward all		Drop	
Time	Type	Direction	Method	URL
17:20:36 19 Apr 2026	HTTP	→ Request	GET	https://news.nankai.edu.cn/mtnk/system/2026/04/18/030071471.shtml

图 10: 拦截请求

点击“Forward”，放行这个请求，发现立即出现了对应的响应，如图11所示。

	Intercept on	Forward	Drop	
Time	Type	Direction	Method	URL
17:20:40 19 Apr 2026	HTTP	→ Request	POST	https://self.events.data.microsoft.com/OneCollector/1.0/
17:21:00 19 Apr 2026	HTTP	→ Request	POST	https://self.events.data.microsoft.com/OneCollector/1.0/
17:20:36 19 Apr 2026	HTTP	← Response	GET	https://news.nankai.edu.cn/mtnk/system/2026/04/18/030071471.shtml

Request

Pretty Raw Hex [Icons]

```

1 GET /mtnk/system/2026/04/18/030071471.shtml HTTP/1.1
2 Host: news.nankai.edu.cn
3 Cookie: Secure
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Chromium";v="146", "Not-A.Brand";v="24", "Microsoft Edge";v="146"
6 Sec-Ch-Ua-Mobile ?1
7 Sec-Ch-Ua-Platform "Android"
8 Upgrade-Insecure-Requests 1
9 User-Agent: Mozilla/5.0 (Linux; Android 10; K) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Mobile Safari/537.36 EdgA/146.0.0.0
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site none
12 Sec-Fetch-Mode navigate
13 Sec-Fetch-User ?1
14 Sec-Fetch-Dest document
15 Accept-Encoding gzip, deflate, br
16 Accept-Language zh-CN,zh;q=0.9
17 Priority: u=0,i
18 Connection: keep-alive
19 
20 
```


Response

Pretty Raw Hex Render

```

1 HTTP/1.1 200 OK
2 Date: Sun, 19 Apr 2026 09:34:31 GMT
3 Content-Type: text/html; charset=utf-8
4 Connection: keep-alive
5 Vary: Accept-Encoding
6 X-XSS-Protection 1; mode=block
7 X-Content-Type-Options nosniff
8 Strict-Transport-Security max-age=31536000; includeSubdomains;
9 Set-Cookie: HttpOnly
10 Set-Cookie: Secure
11 Content-Security-Policy upgrade-insecure-requests;connect-src *
12 X-Protected-By: NKSOC
13 Content-Length 21026
14 
15 <!DOCTYPE HTML PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
16 "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
17 <html xmlns="http://www.w3.org/1999/xhtml">
18   <head>
19     <meta http-equiv="Content-Type" content="text/html; charset=utf-8">
20     <title>
21       南开大学新闻与传播学院2026年4月18日新闻
22     </title>
23     <meta name="keywords" content="">
24     <meta name="description" content="
25       南开大学新闻与传播学院2026年4月18日新闻
26     ">
27     <style>
28       a,h1,h2,h3,h4,h5,h6,u,l,i,body,html,div,span,button,d1,dt,dd,img,p{
29         border:none;
30         margin:0;
31         padding:0;
32       }
33       ul li dd dt{
34         list-style-type:none;
35       }
36     </style>
37   </head>
38   <body>
39     <div class="container">
40       <div class="header">
41         <div class="top">
42           <a href="#">返回首页
43         </div>
44       </div>
45       <div class="content">
46         <div class="main">
47           <h1>南开大学新闻与传播学院2026年4月18日新闻</h1>
48           <p>南开大学新闻与传播学院于2026年4月18日上午10时，在天津校区图书馆报告厅举行2026年度工作总结大会。会议由学院院长王树强主持，全体院属单位负责人、各系所主任及全体教职工代表参加了会议。会议回顾了2025年度学院在教学、科研、社会服务等方面取得的成就，并对2026年的工作目标和任务进行了部署。王院长强调，要进一步加强学科建设，提升教学质量，深化国际交流与合作，为培养高素质新闻传播人才做出更大贡献。会议最后，与会代表纷纷表示，将认真落实会议精神，团结协作，共同推动学院高质量发展。</p>
49         </div>
50       </div>
51     </div>
52   </body>
53 </html>
```

图 11: 拦截响应

让 AI 编写一个被篡改之后的页面，页面的 HTML 代码如下：

HTML

```
<!DOCTYPE html>
<html lang="zh-CN">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Intercepted Page</title>
  <style>
    * {
      box-sizing: border-box;
    }
  </style>

```

```

body {
  margin: 0;
  padding: 0;
  font-family: "Segoe UI", "Microsoft YaHei", Arial, sans-serif;
  background: linear-gradient(135deg, #0f2027, #203a43, #2c5e8a);
  color: #ffffff;
  min-height: 100vh;
  display: flex;
  justify-content: center;
  align-items: center;
}

.container {
  width: 90%;
  max-width: 900px;
  background: rgba(255, 255, 255, 0.08);
  border: 1px solid rgba(255, 255, 255, 0.15);
  border-radius: 20px;
  padding: 40px;
  box-shadow: 0 12px 40px rgba(0, 0, 0, 0.35);
  backdrop-filter: blur(10px);
}

.banner {
  text-align: center;
  margin-bottom: 30px;
}

.banner h1 {
  font-size: 52px;
  margin: 0 0 10px 0;
  color: #ff4d6d;
  text-shadow: 0 0 15px rgba(255, 77, 109, 0.5);
}

.banner p {
  font-size: 18px;
  color: #d9eaf7;
  margin: 0;
}

.panel {
  display: grid;
  grid-template-columns: 1fr 1fr;
  gap: 20px;
  margin-top: 30px;
}

.card {
  background: rgba(255, 255, 255, 0.07);
  border-radius: 16px;
  padding: 20px;
  border-left: 5px solid #ff4d6d;
}

.card h2 {
  margin-top: 0;
  font-size: 22px;
  color: #ffd166;
}

.card p, .card li {
  font-size: 15px;
  line-height: 1.7;
  color: #f1f5f9;
}

```

```

    }

    ul {
        padding-left: 20px;
        margin: 10px 0 0 0;
    }

    .footer {
        margin-top: 30px;
        padding-top: 20px;
        border-top: 1px solid rgba(255, 255, 255, 0.15);
        text-align: center;
        color: #cbd5e1;
        font-size: 14px;
    }

    .btn {
        display: inline-block;
        margin-top: 18px;
        padding: 12px 24px;
        background: #ff4d6d;
        color: white;
        text-decoration: none;
        border-radius: 10px;
        font-weight: bold;
        transition: 0.2s;
    }

    .btn:hover {
        background: #e63956;
    }

    @media (max-width: 700px) {
        .panel {
            grid-template-columns: 1fr;
        }

        .banner h1 {
            font-size: 38px;
        }
    }
</style>
</head>
<body>
    <div class="container">
        <div class="banner">
            <h1>Hacked </h1>
            <p>This page has been intercepted and modified
                successfully.</p>
            <a href="#" class="btn">Continue</a>
        </div>

        <div class="panel">
            <div class="card">
                <h2>System Status</h2>
                <p>The original server response has been replaced with
                    custom HTML content.</p>
                <ul>
                    <li>HTTPS traffic intercepted</li>
                    <li>Response modified in transit</li>
                    <li>Custom page rendered successfully</li>
                </ul>
            </div>

            <div class="card">
                <h2>Test Information</h2>
                <p>This is a demonstration page used for response

```

```

        tampering tests in Burp Suite.</p>
        <ul>
          <li>Client: Mobile Device</li>
          <li>Proxy: Burp Suite</li>
          <li>Mode: Response Interception</li>
        </ul>
      </div>
    </div>

    <div class="footer">
      <p>Security Testing Demo Page · Modified via Proxy
      Response</p>
    </div>
  </div>
</body>
</html>

```

将代码内容完整替换原本的 HTML 代码，然后再次点击 Forward 放行，于是手机的浏览器上出现了被篡改后的网页，如图12所示。

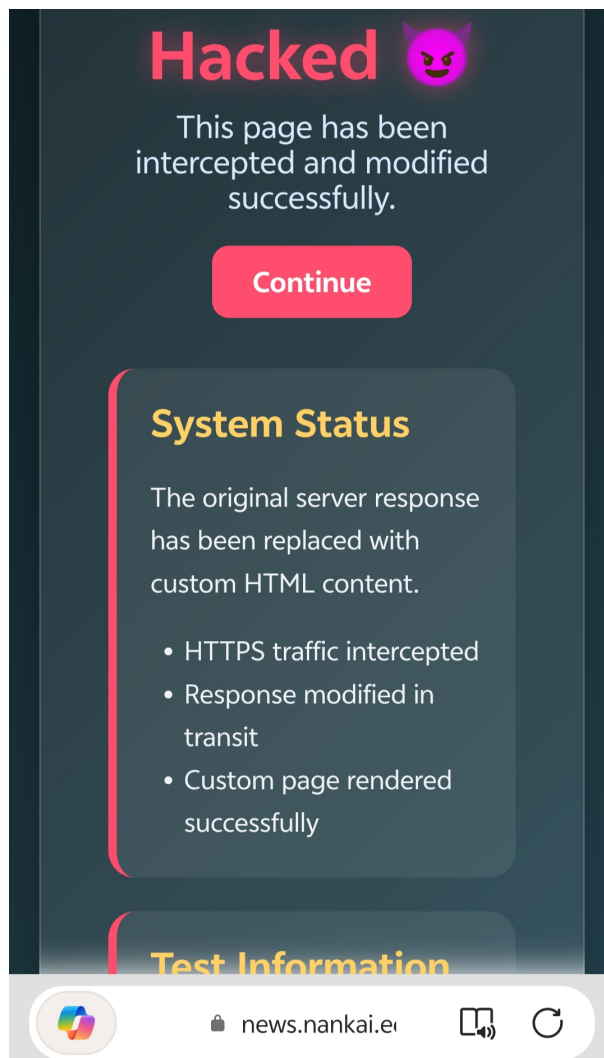


图 12: 被篡改后的网页

3.4 对 APP 的流量进行拦截篡改

我选择 VIVO 手机自带的天气 APP 进行实验，因为这类 APP 没太强安全防护，HTTPS 也可被 Burp Suite 直接解密。

打开 APP，点击“查看更多天气”，如图13所示。我设置只拦截符合要求的响应包，开启拦截后 APP 点击按钮就立即出现了响应包，如图14所示。



图 13: APP 界面

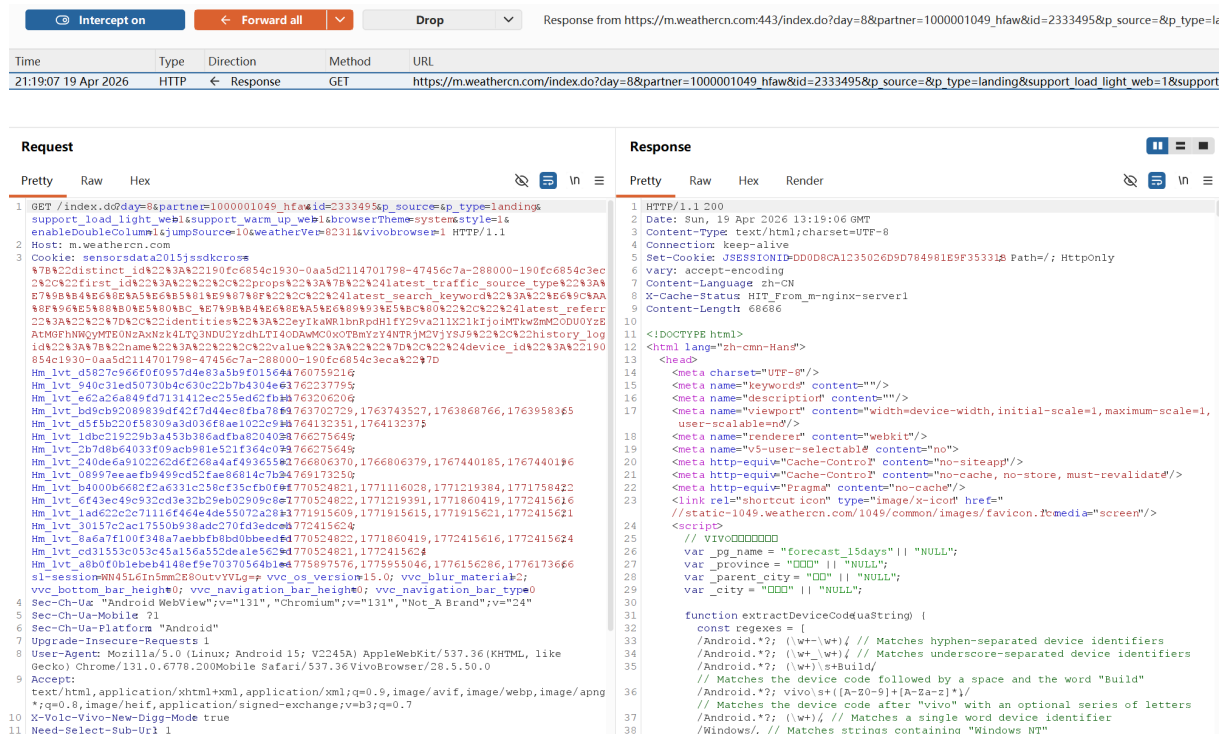


图 14: HTTPS 响应包

现在对响应包里的 HTML 代码做一点修改，例如把明天（4 月 20 日）的最高气温改为 50°C，如图15所示。

Response

PrettyRawHexRender

</div>

<div class="loading-box">

</div>

</div>

<script>

var hasYesterday = true;

var fifteenMinTemp = [

{

y:17.0,dataLabels:{

color:'rgba(0,0,0,0.5)'

},

marker:{

fillColor:'#B7D6FF'

}

},

8,9,12,14,12,15,14,11,12,14,12,13,13,17,14

];

var fifteenMaxTemp = [

{

y:31.0,dataLabels:{

color:'rgba(0,0,0,0.5)'

},

marker:{

fillColor:'#FACAC8'

}

},

28,50,26,24,22,26,25,17,22,25,23,24,24,29,26

];

var MAX_TEMP = Math.max(...[

31.0,28,50,26,24,22,26,25,17,22,25,23,24,24,29,26

]);

var MIN_TEMP = Math.min(...[

17.0,8,9,12,14,12,15,14,11,12,14,12,13,13,17,14

]);

图 15: 被篡改后的 HTTPS 响应包

点击 Forward，手机里就显示出了修改后的界面，明天（4 月 20 日）的最高气温竟然高达 50°C 🤪🤪🤪，如图16所示。

实况 逐小时 单日 15日 90日 天气指数

列表 折线 津南区 >

04/18 04/19 04/20 04/21 04/22 04/23 04/24

昨天 今天 明天 周二 周三 周四 周五

晴 阵雨 晴 晴 多云 晴 晴

50°C

31°C 28°C 26°C 24°C 22°C 20°C

17°C 8°C 9°C 12°C 14°C 12°C 10°C

西南风 西北风 西南风 西南风 西南风 西南风 西南风

4级 5级 3级 1级 1级 1级 1级

轻度 轻度 良 良 良 良 轻度

图 16: 修改后的天气

10

4 实验总结

本次实验通过在电脑端搭建移动热点，实现了对手机 HTTPS 流量的中间人拦截与篡改。实验过程中，不仅成功对浏览器访问的网页进行了响应内容替换，还进一步对手机 APP（如天气应用）的接口数据进行了拦截与修改，并观察到了客户端显示结果的变化（如温度被篡改改为 50°C）。通过实践可以看出，HTTPS 虽然提供了加密通信机制，但在用户信任恶意证书的前提下仍然可能受到中间人攻击，从而导致数据被窃听或篡改。总体而言，本实验加深了对 TLS 通信原理、中间人攻击实现方式以及移动端流量安全问题的理解，具有较强的实践意义。